Risk Assessment and Risk Treatment Process

Implementation of the Information Security Management System

(ISO/IEC 27001:2022)

Document Classification	Internal
Version	1.0
Dated	04/02/27
Document Owner	NX Technologies

Note: NX Technologies is a fictional company. This document is a sample created for learning and portfolio purposes only.

Document Governance & Control

Revision History

VERSION	DATE	AUTHOR	DESCRIPTION
1.0	04/02/27	Aarti Narwade	Initial draft for Risk Assessment and Risk Treatment Process

Distribution

NAME	TITLE
Aakash	CEO
Suvarna	CISO
Rahul	CTO

Approval and Sign-Off

NAME	POSITION	SIGNATURE	DATE
Aakash	CEO	Pending	-
Suvarna	CISO	Pending	-
Rahul	CTO	Pending	-

Contents

1. Introduction.....3
2. Scope.....3
3. Criteria for Performing Information Security Risk Assessment.....3
3.1 Asset Valuation Criteria.....3
3.2 Risk Likelihood and Impact Criteria.....3
3.3 Risk Scoring.....3
4. Risk Management Policy.....4
4.1 Policy Objectives.....4
4.2 Risk Management Principles.....4
4.3 Risk Appetite.....4
4.4 Risk Reporting and Escalation.....4
4.5 Risk Monitoring and Review.....4
5. Risk Assessment Methodology.....5
6. Risk Treatment Process.....5
Risk Treatment Options.....5
Risk Treatment Plan.....5
7. Risk Heat Map.....6
8. Risk Register.....7
9. Risk Treatment Plan.....7
10. Review and Monitoring.....8
10.1 Risk Monitoring.....8
10.2 Review Schedule.....8

1. Introduction

The purpose of this document is to describe the methodology and processes for conducting a risk assessment and determining risk treatment options for NX Technologies. This document aligns with the requirements of ISO/IEC 27001:2022 to ensure the confidentiality, integrity, and availability of information assets.

2. Scope

This risk assessment and risk treatment process applies to all information assets, systems, processes, and personnel within NX Technologies. The scope includes:

- Web server hosted with a third-party provider.
- Cloud-based CRM system.
- Employee Laptops.
- Google Workspace.
- Third Party Application.
- Cloud Infrastructure and Storage

3. Criteria for Performing Information Security Risk Assessment

3.1 Asset Valuation Criteria

Assets are evaluated based on confidentiality, integrity, and availability.

3.2 Risk Likelihood and Impact Criteria

- **Likelihood:** Measures the probability of the risk occurring.
- **Impact:** Measures the consequences if the risk occurs.

Both likelihood and impact are scored on a 5-point scale (1 being low, 5 being high), as shown below.

SCORE	LIKELIHOOD	IMPACT
1	Rare	Negligible
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost Certain	Severe

3.3 Risk Scoring

The Risk Score is calculated by multiplying the likelihood and impact, resulting in a score from 1 to 25, which determines the risk level.

4. Risk Management Policy

NX Technologies is committed to maintaining an effective Information Security Risk Management System in line with ISO/IEC 27001:2022. The policy ensures a systematic and structured approach to risk management, including identification, analysis, evaluation, and treatment of risks.

4.1 Policy Objectives

- To protect the confidentiality, integrity, and availability of information.
- To minimize risks to an acceptable level and ensure business continuity.
- To comply with legal, regulatory, and contractual requirements.

4.2 Risk Management Principles

- **Risk-Based Approach:** Risks will be identified, assessed, and managed in a consistent manner, focusing on reducing risks that may affect business operations.
- **Continual Improvement:** The risk management process will be continuously reviewed and improved based on changes in the threat landscape, business processes, and external requirements.
- **Ownership and Accountability:** All risks will be assigned owners who are responsible for managing, mitigating, and monitoring the risk.

4.3 Risk Appetite

NX_TECH has a LOW appetite for risks to the confidentiality, integrity and availability of customer data and critical business application. It has a MODERATE appetite for risks linked to new features and speed to market. Any risk in the High band cannot be accepted without written CEO approval.

4.4 Risk Reporting and Escalation

Significant risks will be reported to senior management and escalated if necessary. Regular risk reports will be provided to the Chief Information Security Officer (CISO) and senior leadership.

4.5 Risk Monitoring and Review

Risks are to be continuously monitored and reviewed to ensure that mitigation measures are effective and aligned with organizational goals.

5. Risk Assessment Methodology

Risks are assessed using the following steps:

1. **Asset Identification:** Identify the information assets within the scope of the ISMS and assign an owner to each.
2. **Threat and Vulnerability Identification:** Identify the threats and vulnerabilities that could affect the confidentiality, integrity, or availability of each asset.
3. **Risk Analysis:** Rate the likelihood and impact on the 5-point scales and calculate the Risk Score (Likelihood x Impact).
4. **Risk Evaluation:** Prioritize risks based on their Risk Score and compare them against the risk appetite defined in Section 4.3.

6. Risk Treatment Process

Risk Treatment Options

- **Reduce:** Reduce risk through additional controls.
- **Transfer:** Shift risk through contracts or insurance.
- **Avoidance:** Eliminate activities causing the risk.
- **Acceptance:** Accept low and manageable risks.

Risk Treatment Plan

Document the selected risk treatment and assess the Residual Risk after controls have been applied.

7. Risk Heat Map

A Risk Heat Map is a visual tool that plots risks based on their likelihood and impact scores. This helps prioritize which risks need immediate action.

Risk Heat Map Example for NX Technologies

The following is a typical 5x5 Risk Heat Map:

LIKELIHOOD / IMPACT	SEVERE (5)	MAJOR (4)	MODERATE (3)	MINOR (2)	NEGLIGIBLE (1)
Almost Certain (5)	**25 (High)**	**20 (High)**	**15 (High)**	**10 (Medium)**	**5 (Low)**
Likely (4)	**20 (High)**	**16 (High)**	**12 (Medium)**	**8 (Medium)**	**4 (Low)**
Possible (3)	**15 (High)**	**12 (Medium)**	**9 (Medium)**	**6 (Low)**	**3 (Low)**
Unlikely (2)	**10 (Medium)**	**8 (Medium)**	**6 (Low)**	**4 (Low)**	**2 (Low)**
Rare (1)	**5 (Low)**	**4 (Low)**	**3 (Low)**	**2 (Low)**	**1 (Low)**

How to Use the Heat Map:

- **Risk Score 15-25 (High):** Escalate to leadership immediately. Cannot be accepted without written CEO approval.
- **Risk Score 7-14 (Medium):** Treatment plan required within 90 days. Owner reports progress monthly.
- **Risk Score 1-6 (Low):** Accept and monitor. Review at the annual risk review.

Example risks plotted on the map for NX Technologies:

- **CRM Data Breach:** Likelihood 4, Impact 5 = Risk Score 20 (High).
- **Employee Laptop Theft:** Likelihood 3, Impact 4 = Risk Score 12 (Medium).

8. Risk Register

The risk register records each identified risk with its rating, existing controls, planned treatment, and residual risk.

Risk ID	Asset name	Risk title	Threat	Vulnerability	Risk scenario and consequence
R-01	Web Server(Hosted Externally)	Unauthorized access to customer data on the website	External attacker using stolen or phished credentials	MFA is not enforced for administrator access to the hosting console, server and application, and user access is not reviewed periodically.	An attacker gets an admin password through a phishing email. They log in to the website's admin area and copy customer names, emails and course orders. The company must report the breach under GDPR, may get fined, and customers may stop trusting it.
R-02	Cloud-based CRM	Customer data stolen from the CRM	An attacker using a stolen password or an infected laptop	MFA is not turned on for CRM logins, and staff save passwords in browsers on their laptops.	An attacker steals a staff password from an infected laptop and logs in to the CRM. They download the customer list and sales records. The company must report the breach under GDPR, may be fined, and customers may stop trusting it.
R-03	Employee Laptops	Lost or stolen laptop exposes data	Theft or loss while travelling or working remotely	Disk encryption is not enforced on every laptop	Customer data and saved credentials exposed. Likely a reportable incident.
R-04	Google Workspace	Phishing leads to email account takeover	Phishing Emails	MFA is optional for some users; little awareness training	Attacker takes over a mailbox, reads customer data and launches fraud against our customers.
R-05	Third-party Applications	Third-party Application outage	Supplier outage or account suspension	There is no SLA (agreed uptime) with the supplier, no copy of the training materials, and no backup option.	The supplier has an outage or suspends our account over a billing problem. Staff cannot reach training materials for several days. New starters cannot finish onboarding and compulsory training deadlines are missed.
R-06	Cloud Infrastructure and Storage	Unauthorized access to sensitive information	External attacker exploiting misconfigured	Cloud storage access permissions are not	An attacker discovers publicly accessible cloud storage or exploits excessive

		stored in cloud storage	cloud storage permissions	properly restricted, and access reviews are not conducted regularly.	access permissions. They access and download confidential company documents, employee records and customer information. This may result in a data breach, regulatory consequences, financial losses and reputational damage.

9. Risk Treatment Plan

The treatment plan documents the action selected for each risk and the residual risk expected once the action is complete.

Plan ID	Risk ID	Risk title	Inherent rating	Treatment option	Treatment actions (controls)	Action owner	Target date
TP-01	R-01	Unauthorized access to customer data on the website	High	Reduce	1.Turn on MFA for all admin logins to the website, hosting account and database. 2 Remove accounts and permissions that are not needed, then review who has access every quarter. Set up logs and alerts for large data exports and unusual admin logins . 3 Route admin access through single sign-on, and confirm encryption at rest and in transit.	Technical Lead	15-jun-2027
TP-02	R-02	Customer data stolen from the CRM	High	Reduce	1 Turn on MFA for every CRM account. 2 Stop saving passwords in browsers. Roll out a company password manager. 3 Install endpoint protection on all laptops so malware that steals passwords is blocked. 4 Limit CRM export rights to the roles that need them, and alert on large downloads.	CTO	30-jun-2027
TP-	R-	Lost or stolen	Medi	Reduce	1) Enforce full-disk encryption on	Technica	15-

03	03	laptop exposes data	um		every laptop through device management. 2) Enable remote lock and wipe. 3) Give staff a one-page lost-device reporting guide.	l Lead	Aug-2027
TP-04	R-04	Phishing leads to email account takeover	Medium	Reduce	1) Enforce 2-step verification for everyone. Use security keys or passkeys for admins and finance staff, and an authenticator app for others. 2) Annual awareness training plus quarterly phishing simulations. 3) Tighten email filtering and add external-sender warnings.	Technical Lead	31-Jul-2027
TP-05	R-05	Third-party Application outage	Medium	Reduce / Transfer	1) Review the provider contract for an uptime SLA and service credits. 2) Buy business interruption cover that includes supplier outage. 3) Keep a copy of key training materials outside the platform, and share them by email or download link during an outage.	CTO	31-Aug-2027
TP-06	R-06	Unauthorized access to sensitive information stored in cloud storage	High	Reduce	1) Configure cloud storage permissions to ensure only authorized employees can access sensitive information. Apply role-based access control (RBAC) and least privilege. 2) Enable MFA for all cloud storage accounts, especially administrator accounts. 3) Review user access permissions regularly and remove unnecessary or inactive accounts. 4) Enable cloud activity logging and monitor access to sensitive stored information.	Technical Lead	15-Jul-2027

10. Review and Monitoring

10.1 Risk Monitoring

Risks and their mitigation measures will be continuously monitored and reviewed based on:

- The evolving threat landscape.
- Changes in organizational structure or processes.
- New vulnerabilities identified through audits or assessments.

10.2 Review Schedule

- Risk assessments and the treatment plan will be reviewed at least annually.
- A review will be conducted following any significant changes in the environment or after any major incidents.